Mini-projet 1 : Fondamentaux et Identification/Authentification

Partie 1B : Mise en place d'une politique de mot de passe (complexité, renouvellement)

4. Configuration de la Politique de Mot de Passe avec pwquality :

```
# Configuration for systemwide password quality limits
# Defaults:
#
# Number of characters in the new password that must not be present in the
# old password.
 difok = 5
#
# Minimum acceptable size for the new password (plus one if
# credits are not disabled which is the default). (See pam_cracklib manual.)
# Cannot be set to lower value than 6.
 minlen = 12
#
# The maximum credit for having digits in the new password. If less than 0
# it is the minimum number of digits in the new password.
 dcredit = -1
#
# The maximum credit for having uppercase characters in the new password.
# If less than 0 it is the minimum number of uppercase characters in the new
# password.
 ucredit = -1
#
# The maximum credit for having lowercase characters in the new password.
# If less than 0 it is the minimum number of lowercase characters in the new
# password.
 lcredit = -1
#
# The maximum credit for having other characters in the new password.
# If less than 0 it is the minimum number of other characters in the new
# password.
 ocredit = -1
#
# The minimum number of required classes of characters for the new
# password (digits, uppercase, lowercase, others).
 minclass = 4
#
# The maximum number of allowed consecutive same characters in the new password.
# The check is disabled if the value is 0.
 maxrepeat = 3
#
# The maximum number of allowed consecutive characters of the same class in the
# new password.
# The check is disabled if the value is 0.
 maxclassrepeat = 3
#
# Whether to check for the words from the passwd entry GECOS string of the user.
# The check is enabled if the value is not 0.
 gecoscheck = 1
#
```

Configuration de la politique de mots de passe du système dans le fichier pwquality.conf.

Mise en place des restrictions suivantes pour la création de mots de passe système :

Nombre de caractères identiques par rapport à l'ancien mot de passe : au moins 5 caractères différents.

Longueur minimale du mot de passe : 12 caractères.

Nombre de chiffres minimal : au moins 1 chiffre.

Nombre de majuscule minimal : au moins 1 majuscule.

Nombre de minuscule minimal : au moins 1 minuscule.

Nombre de caractères spéciaux minimal : au moins 1 caractère spécial.

Nombre de classe de caractères différentes à utiliser : 4 classes.

5. Application de la Politique de Mot de Passe via PAM :

```
# here are the per-package modules (the "Primary" block)
password        requisite                       pam_pwquality.so retry=3
password        required        pam_unix.so sha512 shadow  nullok try_first_>
# here's the fallback if no module succeeds
```

Modifications de /etc/pam.d/common-password.

6. Configuration du Renouvellement de Mot de Passe (Expiration) :

```
#
# Password aging controls:
#
#       PASS_MAX_DAYS   Maximum number of days a password may be used
#       PASS_MIN_DAYS   Minimum number of days allowed between passwo
#       PASS_WARN_AGE   Number of days warning given before a passwor
#
PASS_MAX_DAYS   90
PASS_MIN_DAYS   0
PASS_WARN_AGE   7
```

Configuration de l'expiration du mot de passe au bout de 90 jours.

```
┌──(kali㉿kali)-[~]
└─$ sudo chage -l kali
Last password change                                    : Dec 03, 2025
Password expires                                        : never
Password inactive                                       : never
Account expires                                         : never
Minimum number of days between password change          : 0
Maximum number of days between password change          : 99999
Number of days of warning before password expires       : 7
```

Affichage de la politique actuelle de mot de passe pour l'utilisateur kali.

```
┌──(kali㉿kali)-[~]
└─$ sudo chage -M 90 kali

┌──(kali㉿kali)-[~]
└─$ sudo chage -l kali
Last password change                                    : Dec 03, 2025
Password expires                                        : Mar 03, 2026
Password inactive                                       : never
Account expires                                         : never
Minimum number of days between password change          : 0
Maximum number of days between password change          : 90
Number of days of warning before password expires       : 7
```

Configuration du nombre de jours avant expiration du mot de passe sur l'utilisateur kali.

7. Test de la Politique de Mot de Passe :

```
New password:
BAD PASSWORD: The password contains more than 3 characters of the same class
consecutively
```

Test du mot de passe : court. Le mot de passe a plus de trois caractères d'affilé appartenant à la même classe.

```
New password:
BAD PASSWORD: The password contains less than 1 digits
```

Test du mot de passe : PaSwOrDiT. Le mot de passe ne contient pas de chiffres.

```
New password:
Retype new password:
passwd: password updated successfully
```

Test du mot de passe : M0+d3p4ss3_16. Mot de passe mise à jour avec succès.

Partie 1C : Configuration de l'authentification SSH avec échange de clés

```
┌──(kali㉿kali)-[~/Downloads]
└─$ sudo ssh -i ssh-key-2026-02-08.key ubuntu@158.178.210.50
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-1041-oracle x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Sun Mar 15 10:46:53 UTC 2026

  System load:  0.0                Processes:             139
  Usage of /:   9.9% of 44.96GB    Users logged in:       1
  Memory usage: 2%                 IPv4 address for ens3: 10.0.0.12
  Swap usage:   0%
```

J'ai directement utilisé cette commande en modifiant des paramètres du serveur Ubuntu car j'avais du mal à faire la commande :

```
┌──(kali㉿kali)-[~]
└─$ sudo ssh-copy-id ubuntu@158.178.210.50
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be installed:
/usr/bin/ssh-copy-id: ERROR: No identities found
```

4. Désactiver l'authentification par mot de passe sur le serveur SSH (VM Ubuntu) :

```
  GNU nano 6.2                    /etc/ssh/sshd_config *

#AuthorizedKeysCommand none
#AuthorizedKeysCommandUser nobody

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
#HostbasedAuthentication no
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
#IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
PasswordAuthentication no
#PermitEmptyPasswords no
```

```
ubuntu@instance-victim:~$ sudo systemctl restart sshd
ubuntu@instance-victim:~$
```

5. Vérifier la désactivation du mot de passe :

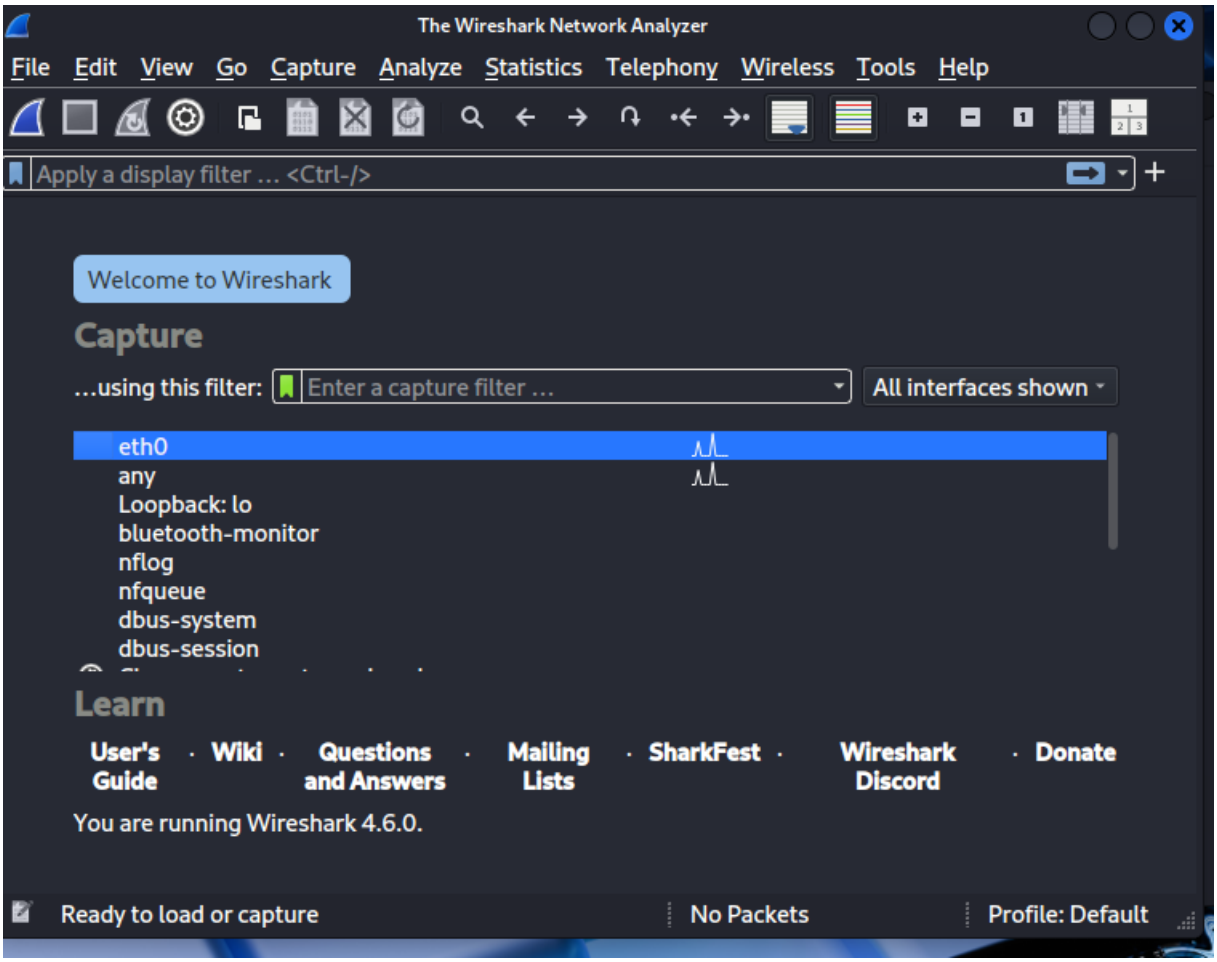
```
┌──(kali㉿kali)-[~/Downloads]
└─$ sudo ssh -i ssh-key-2026-02-08.key ubuntu@158.178.210.50
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-1041-oracle x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Sun Mar 15 10:46:53 UTC 2026

  System load:  0.0                Processes:             139
  Usage of /:   9.9% of 44.96GB    Users logged in:       1
  Memory usage: 2%                 IPv4 address for ens3: 10.0.0.12
  Swap usage:   0%
```

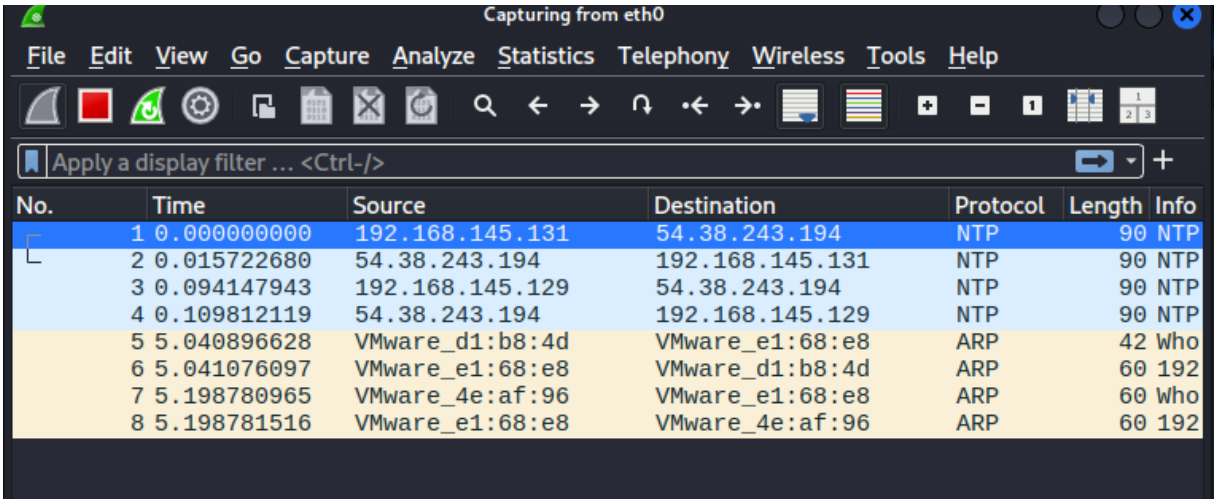
```
┌──(kali㉿kali)-[~/Downloads]
└─$ ssh -o PreferredAuthentications=password ubuntu@158.178.210.50
ubuntu@158.178.210.50: Permission denied (publickey).
```

La commande où le mot de passe est forcé semble ne pas marcher mais il ne semble pas que l'erreur provienne du mot de passe.

Partie 1D : Introduction aux outils d'attaque et de test (Wireshark, Nmap, etc.)

1. Wireshark - Capture et Analyse de Base (sur la VM Analyseur Kali Linux) :





La capture a commencé sur Wireshark sur l'interface eth0.

Générer du trafic réseau (depuis une autre VM ou la VM Kali elle-même) :

```
┌──(kali㉿kali)-[~]
└─$ ping -c 5 158.178.210.50
PING 158.178.210.50 (158.178.210.50) 56(84) bytes of data.
64 bytes from 158.178.210.50: icmp_seq=1 ttl=128 time=12.0 ms
64 bytes from 158.178.210.50: icmp_seq=2 ttl=128 time=9.54 ms
64 bytes from 158.178.210.50: icmp_seq=3 ttl=128 time=10.1 ms
64 bytes from 158.178.210.50: icmp_seq=4 ttl=128 time=8.25 ms
64 bytes from 158.178.210.50: icmp_seq=5 ttl=128 time=9.55 ms

--- 158.178.210.50 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4007ms
rtt min/avg/max/mdev = 8.254/9.884/11.969/1.207 ms
```

Paquets ICMP repérés :

102	309.237655479	192.168.145.129	158.178.210.50	ICMP	98 Ec
103	309.247381533	158.178.210.50	192.168.145.129	ICMP	98 Ec
104	310.237281052	192.168.145.129	158.178.210.50	ICMP	98 Ec
105	310.246334367	158.178.210.50	192.168.145.129	ICMP	98 Ec
106	311.239639958	192.168.145.129	158.178.210.50	ICMP	98 Ec
107	311.249290786	158.178.210.50	192.168.145.129	ICMP	98 Ec
108	312.241349224	192.168.145.129	158.178.210.50	ICMP	98 Ec
109	312.249403558	158.178.210.50	192.168.145.129	ICMP	98 Ec
110	313.243011634	192.168.145.129	158.178.210.50	ICMP	98 Ec

Exercice :

```
Internet Protocol Version 4, Src: 192.168.145.129, Dst: 158.178.210.50
    0100 .... = Version: 4
```

La source des paquets est l'adresse 192.168.145.129.

La destination des paquets est l'adresse 158.178.210.50.

```
▾ Internet Control Message Protocol
    Type: Echo (ping) request (8)
    Code: 0
```

Il s'agit d'une requête de type ping.

2. Nmap - Scan de Ports de Base (sur la VM Attaquant Kali Linux) :

```
┌──(kali㉿kali)-[~]
└─$ nmap -sS 158.178.210.50
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 08:55 EDT
Nmap scan report for 158.178.210.50
Host is up (0.0026s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT   STATE SERVICE
22/tcp open  ssh

Nmap done: 1 IP address (1 host up) scanned in 4.26 seconds
```

La machine ciblée à le port 22 ouvert et le service ssh actif.

```
┌──(kali㉿kali)-[~]
└─$ nmap --fast 158.178.210.50
/usr/lib/nmap/nmap: unrecognized option '--fast'
See the output of nmap -h for a summary of options.
```

L'option –fast semble ne pas être présente sur ma machine Kali.

Exercice :

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 158.178.210.50
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 09:04 EDT
Nmap scan report for 158.178.210.50
Host is up (0.016s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.14 (Ubuntu Linux; protoco
 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 55.68 seconds
```

Le seul service détecté est le service ssh sur le port TCP 22

```
┌──(kali㉿kali)-[~]
└─$ nmap -sS -sU 158.178.210.50
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 09:09 EDT
Nmap scan report for 158.178.210.50
Host is up (0.00055s latency).
Not shown: 1000 open|filtered udp ports (no-response), 999 filtered tcp ports
 (no-response)
PORT   STATE SERVICE
22/tcp open  ssh

Nmap done: 1 IP address (1 host up) scanned in 62.50 seconds
```

Le scan détecte un seul service en fonctionnement, le service ssh sur le port TCP 22.

Partie 1E : Mise en place de protection basique (exemple : firewall basique)

1. Vérification du Statut Actuel d'iptables (VM Ubuntu - Serveur) :

```
ubuntu@instance-victim:~$ sudo iptables -L
Chain INPUT (policy ACCEPT)
target     prot opt source               destination
ACCEPT     all  --  anywhere             anywhere             state RELATED,E
STABLISHED
ACCEPT     icmp --  anywhere             anywhere
ACCEPT     all  --  anywhere             anywhere
ACCEPT     tcp  --  anywhere             anywhere             state NEW tcp d
pt:ssh
REJECT     all  --  anywhere             anywhere             reject-with icm
p-host-prohibited

Chain FORWARD (policy ACCEPT)
target     prot opt source               destination
REJECT     all  --  anywhere             anywhere             reject-with icm
p-host-prohibited

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination
InstanceServices  all  --  anywhere             link-local/16

Chain InstanceServices (1 references)
target     prot opt source               destination
ACCEPT     tcp  --  anywhere             169.254.0.2          owner UID match
 root tcp dpt:iscsi-target /* See the Oracle-Provided Images section in the O
```

Observation des chaînes Input, Forward et Output.

2. Mise en Place d'une Règle de Firewall Basique : Bloquer le Ping (ICMP INPUT) :

```
ubuntu@instance-victim:~$ sudo iptables -A INPUT -p icmp --icmp-type echo-req
uest -j DROP
ubuntu@instance-victim:~$ sudo iptables -L
Chain INPUT (policy ACCEPT)
target     prot opt source               destination
ACCEPT     all  --  anywhere             anywhere             state RELATED,E
STABLISHED
ACCEPT     icmp --  anywhere             anywhere
ACCEPT     all  --  anywhere             anywhere
ACCEPT     tcp  --  anywhere             anywhere             state NEW tcp d
pt:ssh
REJECT     all  --  anywhere             anywhere             reject-with icm
p-host-prohibited
DROP       icmp --  anywhere             anywhere             icmp echo-reque
st
```

Ajout et observation de la nouvelle règle ajoutée.

3. Test de la Règle : Ping depuis la VM Kali Linux (Client) vers la VM Ubuntu

```
┌──(kali㉿kali)-[~]
└─$ ping 158.178.210.50
PING 158.178.210.50 (158.178.210.50) 56(84) bytes of data.
^C
--- 158.178.210.50 ping statistics ---
14 packets transmitted, 0 received, 100% packet loss, time 13310ms
```

4. Autoriser le Trafic SSH Entrant (TCP INPUT port 22) :

```
ubuntu@instance-victim:~$ sudo iptables -L
Chain INPUT (policy ACCEPT)
target     prot opt source               destination
ACCEPT     tcp  --  anywhere             anywhere             tcp dpt:ssh
DROP       icmp --  anywhere             anywhere             icmp echo-reque
```

5. Test de la Règle SSH : Connexion SSH depuis la VM Kali Linux (Client) vers la VM Ubuntu (Serveur)

```
┌──(kali㉿kali)-[~/Downloads]
└─$ sudo ssh -i ssh-key-2026-02-08.key ubuntu@158.178.210.50
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-1044-oracle x86_64)
```

Le trafic SSH est bien accepté.

6. Politique par Défaut de la Chaîne INPUT (Optionnel, pour aller plus loin) :

```
ubuntu@instance-victim:~$ sudo iptables -L
Chain INPUT (policy ACCEPT)
target     prot opt source               destina
```

La politique de la chaîne INPUT est bien ACCEPT.

```
ubuntu@instance-victim:~$ sudo iptables -P INPUT DROP
ubuntu@instance-victim:~$ sudo iptables -L
Chain INPUT (policy DROP)
target     prot opt source               destination
```

Changement de la politique de la chaîne INPUT à DROP.

7. Suppression des Règles iptables (Nettoyage) :

```
ubuntu@instance-victim:~$ sudo iptables -D INPUT 1
ubuntu@instance-victim:~$ sudo iptables -L
Chain INPUT (policy DROP)
target     prot opt source               destination
ACCEPT     all  --  anywhere             anywhere             state RELATED,E
STABLISHED
ACCEPT     icmp --  anywhere             anywhere
ACCEPT     all  --  anywhere             anywhere
ACCEPT     tcp  --  anywhere             anywhere             state NEW tcp d
pt:ssh
REJECT     all  --  anywhere             anywhere             reject-with icm
p-host-prohibited
```

Les politiques ont bien été supprimées.

```
ubuntu@instance-victim:~$ sudo iptables -F INPUT
ubuntu@instance-victim:~$ Read from remote host 158.178.210.50: Connection r
set by peer
Connection to 158.178.210.50 closed.
client_loop: send disconnect: Broken pipe

┌──(kali㉿kali)-[~/Downloads]
└─$ sudo ssh -i ssh-key-2026-02-08.key ubuntu@158.178.210.50
[sudo] password for kali:
^C

┌──(kali㉿kali)-[~/Downloads]
└─$
```

La machine ubuntu n’est plus accessible par ssh.